

Защита в операционных системах

Глубокое погружение в механизмы безопасности Windows и Linux

Беликов Владимир Вячеславович

План выступления

1. **Введение:** Эволюция угроз и ответных мер.
2. **Фундаментальные механизмы:**
 - Аутентификация
 - Авторизация и MAC
 - Дискреционный контроль доступа (DAC)
 - Шифрование
 - Аудит
3. **Современные системы:**
 - Сетевая защита хоста
 - HIPS
 - EDR
 - SIEM, XDR, TI, IoC
4. **Будущее(настоящее):** Machine Learning (ML)
5. **Заключение**

Защита процесса загрузки ОС

Теория: Защита загрузки ОС. Цепочка доверия (Chain of Trust)

Цель — обеспечить, что каждый этап загрузки проверяет подлинность и целостность следующего, прежде чем передать ему управление. Это предотвращает запуск неавторизованного кода (руткитов) на ранних этапах.

Ключевые угрозы:

- Компрометация загрузчика (`bootkit`)
- Подмена ядра ОС
- Отключение механизмов защиты (например, SELinux)

Схематичный порядок загрузки и проверки:

1. UEFI Firmware
└─ (Проверяет подпись)
2. Загрузчик (GRUB2 shim.efi)
└─ (Проверяет подпись GRUB2 и ядра)
3. Ядро Linux (vmlinuz)
└─ (Проверяет подпись модулей ядра)
4. Initramfs (initrd)
5. Пользовательское пространство (systemd)
└─ (Монтирование зашифрованных разделов)

Аутентификация

Теория: Проверка подлинности субъекта. Основа безопасности.

Эволюция: пароли → MFA, биометрия, сертификаты.

Практика: Linux

- **PAM (Pluggable Authentication Modules):** Гибкий фреймворк (`pam_google_authenticator` , `pam_tally2`).
- **SSH Keys:** Стандарт для безопасного удаленного доступа.
- **Файлы:** `/etc/passwd` , `/etc/shadow` , `/etc/ssh/sshd_config` .

Практика: Windows

- **Active Directory:** Централизованная аутентификация (Kerberos, NTLM).
- **Windows Hello:** Биометрия и PIN.
- **LSA:** Подсистема локальной аутентификации.
- **Компоненты:** `LSASS.exe` , SAM.

Дискреционное управление доступом

Теория: Модель, где владелец объекта сам решает, кому предоставить доступ. Реализуется через ACL (контрольные списки доступа) и Unix-permissions

Практика: Linux

- **Классические права:** `rwX` для user/group/others (`chmod` , `chown`).
- **Расширенные атрибуты:** `setfacl` / `getfacl` для настройки ACL.

Практика: Windows

- **NTFS Permissions:** Сложная система ACL (наследование, явный запрет).
- **Инструменты:** Проводник -> Свойства -> Безопасность, `icacls` .

Авторизация и Мандатный контроль доступа (MAC)

Теория: Определение прав доступа. MAC — права назначаются централизованной политикой, а не владельцем.

Практика: Linux

- **SELinux (Security-Enhanced Linux):** Реализация MAC от NSA.
 - **Режимы:** Enforcing, Permissive.
 - **Контексты:** `ls -Z` (пользователь, роль, тип).
- **AppArmor:** Основан на путях файловой системы.

Практика: Windows

- **Mandatory Integrity Control (MIC):** Механизм меток целостности (Low, Medium, High, System).
- **Реализация:** `icacls`, "манифесты" исполняемых файлов.

Шифрование данных

Теория: Защита конфиденциальности данных на диске и в памяти.

Практика: Linux

- **LUKS:** Стандарт для полнодискового шифрования (FDE).
- **eCryptfs:** Шифрование на уровне файловой системы.
- **DM-Crypt:** Low-level механизм в ядре.

Практика: Windows

- **BitLocker:** Полнодисковое шифрование. Интегрирован с TPM-чипом.
- **EFS:** Шифрование на уровне файлов/каталогов.

Аудит и логирование

Теория: Фундамент для обнаружения и расследования инцидентов.

Практика: Linux

- **auditd:** Демон аудита для отслеживания системных вызовов.
- **Журналы:** `/var/log/` (`auth.log` , `secure`), подсистема `journald`
- **Утилиты:** `ausearch` , `aureport` .

Практика: Windows

- **Windows Event Log:** Централизованная система журналов.
 - **Каналы:** Security, System, Application.
 - **Коды событий:** 4624/4625 (вход), 4688 (процесс).
- **Инструменты:** Event Viewer, `wevtutil` .

Сетевая защита хоста

Теория: Контроль сетевого трафика на уровне отдельного хоста.

Практика: Linux

- **netfilter/iptables/nftables:** Фреймворк фильтрации пакетов в ядре.
- **Пример:** `iptables -A INPUT -p tcp --dport 22 -j ACCEPT`

Практика: Windows

- **Windows Defender Firewall:** Stateful firewall с гибкими правилами.
- **Инструменты:** `wf.msc` , PowerShell (`New-NetFirewallRule`).

Вредоносное ПО (ВПО / Malware) - Основная угроза

Цель: Несанкционированное проникновение, нарушение конфиденциальности, целостности или доступности системы.

Основные классы для ОС:

- **Вирусы / Черви:** Самореплицирующиеся, заражают файлы/распространяются по сети.
- **Трояны (Trojans):** Маскируются под легитимное ПО.
- **Руткиты (Rootkits):** Маскируют свое присутствие в системе (в ядре или пользовательском пространстве).
- **Шпионское ПО (Spyware):** Кража данных (кейлоггеры, сбор cookies).
- **Рансомвер (Ransomware):** Шифрование данных для выкупа.
- **Криптоджекеры (Cryptojackers):** Несанкционированный майнинг криптовалюты.

Вредоносное ПО (ВПО / Malware)

Практика: Linux

- **Источники угроз:** Непроверенные репозитории, скомпрометированные пакеты (`npm` , `pip`), уязвимости в серверном ПО.
- **Особенности:** Часто нацелено на серверы для создания ботнетов, криптоджекинга или шифрования данных (ransomware для серверов).
- **Примеры:** **XorDDoS** (ботнет), **Linux.Ransom** (рансомвер).

Практика: Windows

- **Источники угроз:** Фишинговые письма с вложениями, вредоносные сайты, сомнительное ПО (кейгены, пиратский софт).
- **Особенности:** Широкий охват пользователей. Часто нацелено на кражу учетных записей, банковских данных, шифрование файлов.
- **Примеры:** **Emotet** (троян-дроппер), **Conti** (рансомвер), **TrickBot** (банковский троян).

HIPS - Host-based Intrusion Prevention System, система предотвращения вторжений

Теория: Анализ поведения системы в реальном времени для блокировки подозрительной активности.

Практика: Linux

- **Fail2Ban:** Сканирует логи и блокирует IP при атаках.
- **OSSEC:** HIPS с обнаружением изменений файлов (FIM).

Практика: Windows

- **Microsoft Defender:** Включает компоненты HIPS:
 - Контролируемый доступ к папкам (защита от ransomware).
 - Защита от подделки.
 - Эксплойт-гард.

EDR (Endpoint Detection and Response)

Теория: Платформа для сбора телеметрии с конечных точек. Возможности:

- **Обнаружения** сложных атак.
- **Расследования** инцидентов.
- **Реагирования** на инциденты.

Практика: Linux & Windows

- **Агенты:** Устанавливается агент (CrowdStrike, SentinelOne, Defender for Endpoint).
- **Ключевые возможности:**
 - Поведенческий анализ (Behavioral Analysis)
 - Проактивный поиск угроз (Threat Hunting)
 - Визуализация цепочки компрометации (Kill Chain visualization)

SIEM (Security Information and Event Management)

Теория: Централизованный сбор, агрегация и анализ событий с *множества* источников.

Практика: Linux & Windows

- **Агенты:** Elastic Agent, Splunk Forwarder для отправки логов в центр.
- **Примеры:** Splunk, Elastic Stack (ELK), QRadar.
- **Сценарий:** Корреляция события входа, сетевого подключения и подозрительного процесса → выявление атаки.

XDR (Extended Detection and Response)

Эволюция EDR. Интегрирует данные с ОС, сети, облака и почты для построения единой картины атаки.

- **Роль ОС:** Ключевой источник телеметрии. Атака начинается на конечной точке.

Threat Intelligence (TI) и IoC

TI — это "знания о противнике". **IoC** — конкретные улики его деятельности.

- **Роль ОС:** Механизмы защиты (EDR, AV) проверяют артефакты *внутри* ОС (файлы, реестр, соединения) на совпадение с IoC.
- **Пример:** Получив IoC на хэш вредоноса, EDR проверяет его на всех хостах и блокирует выполнение.

Общая концепция: Защита ОС перестала быть изолированной. Это часть большой экосистемы, где данные с ОС обогащаются контекстом извне (TI) и коррелируются с событиями с других уровней (XDR).

Machine Learning в защите ОС

Теория: Анализ телеметрии для выявления аномалий, невидимых сигнатурным методам.

Практика: Применение

1. **Обнаружение аномалий:** Профиль "нормального" поведения.
 2. **Классификация угроз:** Файлы malicious/benign.
 3. **Прогнозирование атак:** Анализ TTPs.
- **Где используется:** Внутри EDR (Microsoft, CrowdStrike), антивирусы.

Заключение

- Защита ОС — это **многоуровневая оборонная стратегия** (Defense in Depth).
- Эволюция: статические механизмы → интеллектуальные системы.
- Современная защита — это **видимость** и **контекст**.
- **Тренды:** Конвергенция (EDR+AV+FW), облачные сервисы (MDR), AI/ML.
- **Важно:** Понимать основы (ACL, аудит) для работы с EDR/SIEM.

Спасибо за внимание!

Вопросы?

ТГ: @james_white_116